Enhancing system security through identity based on context aware access control

LIST OF TEAMMATES:

S.no	Names	College name	Contact
1.	HARIPRIYA M	SRI KRISHNA ADITHYA COLLEGE OF ARTS AND SCIENCE	23bscs216haripriyam@skacas.ac.in
2.	KRITIK PRANAV B	SRI KRISHNA ADITHYA COLLEGE OF ARTS AND SCIENCE	23bscs268kritikpranavb@skacas.ac.in
3	UDHAYANITHI K	SRI KRISHNA ADITHYA COLLEGE OF ARTS AND SCIENCE	23bscs262udhayanithik@skacas.ac.in
4	SHALIK S	SRI KRISHNA ADITHYA COLLEGE OF ARTS AND SCIENCE	23bscs253shaliks@skacas.ac.in
5	VARSHATH S	SRI KRISHNA ADITHYA COLLEGE OF ARTS AND SCIENCE	23bscs264varshaths@skacas.ac.in

Project Title

Title: Enhancing system security through identity based on context aware access control

• AI-Enhanced User Protection (AIUP):

Enhancing System Security Through Identity-Based Context-Aware Access Control is an advanced security approach that manages and protects system access by analysing both user identity and contextual information such as location, device type, login time, and network environment. Unlike traditional access control systems that rely mainly on static credentials like usernames and passwords, this system dynamically evaluates the context in which the access request is made before granting permission.

This approach improves cybersecurity by ensuring that access decisions are based not only on identity verification but also on the surrounding conditions of the access request. For example, if a user attempts to log in from an unusual location, an unknown device, or at an abnormal time, the system can detect the irregular activity and request additional authentication such as a one-time password (OTP) or temporarily restrict access.

By continuously analysing contextual factors and user behaviour, the system can identify potential security risks and prevent unauthorized access to sensitive resources. This intelligent mechanism helps organizations protect confidential data and maintain secure digital environments.

In modern digital infrastructures where cyber threats are constantly evolving, identity-based context-aware access control provides a smarter and more reliable security solution. By combining user identity verification with contextual awareness, the system ensures that only legitimate users can access system resources under trusted conditions, thereby strengthening overall system security..

Introduction

In the modern digital era, organizations and individuals rely heavily on online systems to store, process, and access sensitive information. With the rapid growth of technology, the number of cyber threats and security attacks has also increased significantly. Protecting digital systems from unauthorized access has become a major challenge for organizations across various sectors such as banking, healthcare, education, and corporate environments. Traditional access control systems primarily depend on static authentication methods such as usernames and passwords to verify user identity. Although these methods provide a basic level of security, they are often not sufficient to protect systems from modern cyber threats.

Many cyber-attacks occur because attackers obtain valid user credentials through techniques such as phishing, credential theft, or brute-force attacks. Once attackers gain access to login credentials, traditional systems may allow them to access sensitive resources without further verification. This limitation highlights the need for more advanced access control mechanisms that can analyze additional information before granting system access.

To address this issue, the concept of context-aware access control has emerged as an effective security solution. Context-aware access control systems consider not only the user's identity but also contextual factors related to the access request. These contextual factors may include the user's device type, geographic location, login time, and network environment. By analyzing this information, the system can determine whether the access request is legitimate or suspicious.

The project titled "Enhancing System Security Through Identity-Based Context-Aware Access Control" focuses on designing a smart security mechanism that integrates user identity verification with contextual analysis. When a user attempts to log into the system, the system first authenticates the user and then evaluates the context in which the login request is made. If the login attempt matches trusted conditions, the system grants access to the user. However, if the system detects unusual behavior such as login attempts from an unknown device or unexpected location, it may trigger additional authentication or restrict access.

This approach helps strengthen system security by ensuring that access decisions are based on multiple factors rather than relying only on passwords. By implementing identity-based context-aware access control, organizations can better protect sensitive information, detect suspicious activities, and prevent unauthorized access to digital resources.

Abstract:

In today's digital environment, protecting sensitive information and preventing unauthorized access to systems has become increasingly important. Traditional access control mechanisms mainly rely on static authentication methods such as usernames and passwords. Although these methods provide basic security, they are often vulnerable to modern cyber threats including credential theft, phishing attacks, brute-force attempts, and unauthorized login activities. Therefore, there is a growing need for more advanced and intelligent access control mechanisms that can improve system security.

The project titled "Enhancing System Security Through Identity-Based Context-Aware Access Control" proposes a smart security approach that combines user identity verification with contextual information to make more reliable access control decisions. Instead of granting access based only on login credentials, the system evaluates additional contextual factors such as the user's device type, geographic location, login time, and network environment. By analyzing these parameters, the system can determine whether an access request is normal or potentially suspicious.

When a user attempts to log in, the system first authenticates the user's identity and then examines the contextual information related to the login attempt. If the context matches trusted conditions, access is granted smoothly. However, if unusual behaviour is detected, such as login attempts from unknown devices or unfamiliar locations, the system may request additional verification or temporarily restrict access to prevent potential security risks.

This context-aware approach strengthens system security by enabling dynamic and adaptive access control decisions. It helps organizations protect sensitive data, reduce the risk of unauthorized access, and detect suspicious activities more effectively. The proposed system provides a balance between security and usability by ensuring that legitimate users can access resources easily while maintaining strong protection against cyber threats.

Use Case Scenarios:

Scenario 1: Authorized User Login from Trusted Device

A registered user attempts to log into the system using their correct username and password from a trusted device such as their personal laptop. The system verifies the user's identity and analyzes contextual information including device type, location, login time, and network environment. Since the login request matches the previously trusted conditions, the system allows the user to access the system without any additional verification..

Output:

- User identity successfully authenticated
- Trusted device and location verified
- Access granted to authorized resources

Scenario 2: Login Attempt from Unknown Device

A registered user tries to log into the system from a new or unrecognized device. Although the user provides correct login credentials, the system detects that the device has not been previously used to access the account. To ensure security, the system requests additional verification such as a One-Time Password (OTP) before granting access.

Output:

- User identity verified
- Device detected as untrusted
- Additional authentication (OTP) requested
- Access granted after successful verification

Scenario 3: Access Attempt from Suspicious Location

A user attempts to access the system from a geographic location that has never been associated with the user's account before. Even though the credentials are correct, the system identifies the location as unusual and flags the login request as suspicious. The system temporarily restricts access and sends a security alert.

Output:

- Unusual login location detected
- Access temporarily restricted
- Security alert generated

Scenario 4: Authorized Admin Access to Sensitive Data

A system administrator logs into the system to perform maintenance tasks or access sensitive organizational data. The system verifies the administrator's credentials, role permissions, and contextual information such as device and network security. Since the request meets all trusted conditions, the system grants access to restricted administrative resources.

Output:

- Admin identity and role verified
- Trusted device and secure network confirmed
- Access granted to sensitive administrative data

Scenario 5: Multiple Failed Login Attempts

An unknown user repeatedly attempts to log into the system using incorrect credentials. The system detects multiple failed login attempts from the same IP address within a short period. To prevent brute-force attacks, the system temporarily blocks the IP address and logs the suspicious activity.

Output:

- Multiple failed login attempts detected
- IP address temporarily blocked
- System protected from unauthorized access attempts

Scenario 6: Login Attempt Outside Normal Login Time

A registered user attempts to log into the system at an unusual time, such as late at night or outside the user's normal working hours. Even though the user provides correct login credentials, the system detects that the login time is different from the user's typical login pattern. To ensure security, the system requests additional authentication before granting access.

Output:

- User credentials verified
- Unusual login time detected
- Additional verification required
- Access granted after successful authentication

Scenario 7: Access Request to Restricted Resource by Unauthorized User

A registered user attempts to access a restricted resource or sensitive data that is not permitted for their role.The system verifies the user's identity but detects that the requested resource is outside the user's authorization level. As a result, the system denies access and logs the attempt.

Output:

- User identity verified
- Unauthorized resource access attempt detected
- Access denied
- Security log updated

Scenario 8: Access Attempt from Public or Insecure Network

A registered user attempts to log into the system using correct credentials from a public Or unsecured network, such as public Wi-Fi in a café or airport. The system analyzes the network context and detects that the network environment may not be secure. To protect the user's account and sensitive data, the system enforces additional security measures before granting access.

Output:

- User credentials verified
- Insecure or public network detected
- Additional security verification required
- Access granted after successful verification

Stage-1

Overview:

Title: Enhancing System Security Through Identity-Based Context-Aware Access Control

In today's digital world, protecting sensitive information and preventing unauthorized access to systems has become a critical challenge for organizations and individuals. Traditional access control mechanisms mainly rely on static authentication methods such as usernames and passwords to verify users. Although these methods provide a basic level of protection, they are often vulnerable to modern cyber threats such as phishing attacks, credential theft, brute-force attacks, and unauthorized login attempts. As cyber threats continue to grow, relying only on static credentials is no longer sufficient to ensure strong system security.

The concept of context-aware access control has emerged as a more advanced and effective approach to address these security challenges. Context-aware access control systems make access decisions not only based on user identity but also by analyzing contextual information related to the access request. These contextual factors may include the user's device type, geographic location, login time, and network environment. By evaluating these parameters, the system can determine whether the login attempt is legitimate or potentially suspicious.

The project titled "Enhancing System Security Through Identity-Based Context-Aware Access Control" focuses on designing and implementing a smart access control system that integrates identity verification with contextual analysis. When a user attempts to access the system, the system first verifies the user's identity using authentication credentials. After successful authentication, the system analyzes contextual information such as whether the login request is coming from a trusted device, a recognized location, or within the expected usage time.

If the login request matches the trusted conditions, the system grants access to the user without interruption. However, if unusual behavior is detected, such as login attempts from unknown devices or suspicious locations, the system may request additional verification or temporarily restrict access. This adaptive security mechanism helps prevent unauthorized access and protects sensitive information.

By combining identity-based authentication with contextual awareness, the proposed system improves the accuracy and reliability of access control decisions. It also helps organizations detect suspicious activities, reduce security risks, and maintain secure digital environments. Overall, this project demonstrates how intelligent access control mechanisms can enhance system security while maintaining a smooth and user-friendly experience for legitimate users.

List of Vulnerabilities:

S.no	Vulnerability name	CWE-NO
1.	Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')	CWE-22
2.	J2EE Misconfiguration: Data Transmission Without Encryption	CWE-5
3.	Unimplemented or Unsupported Feature in UI	CWE-447
4.	weak Encoding For Password	CWE-261
5.	improper Input Validation	CWE-20
6.	External Control of File Name or Path	CWE-73
7.	Empty Password in Configuration file	CWE-258
8.	Insufficient Verification of Data Authenticity	CWE-345
9.	Improper Output Neutralization for Logs	CWE-117
10.	Generation of Error Message Containing Sensitive Information	CWE-209

REPORT:

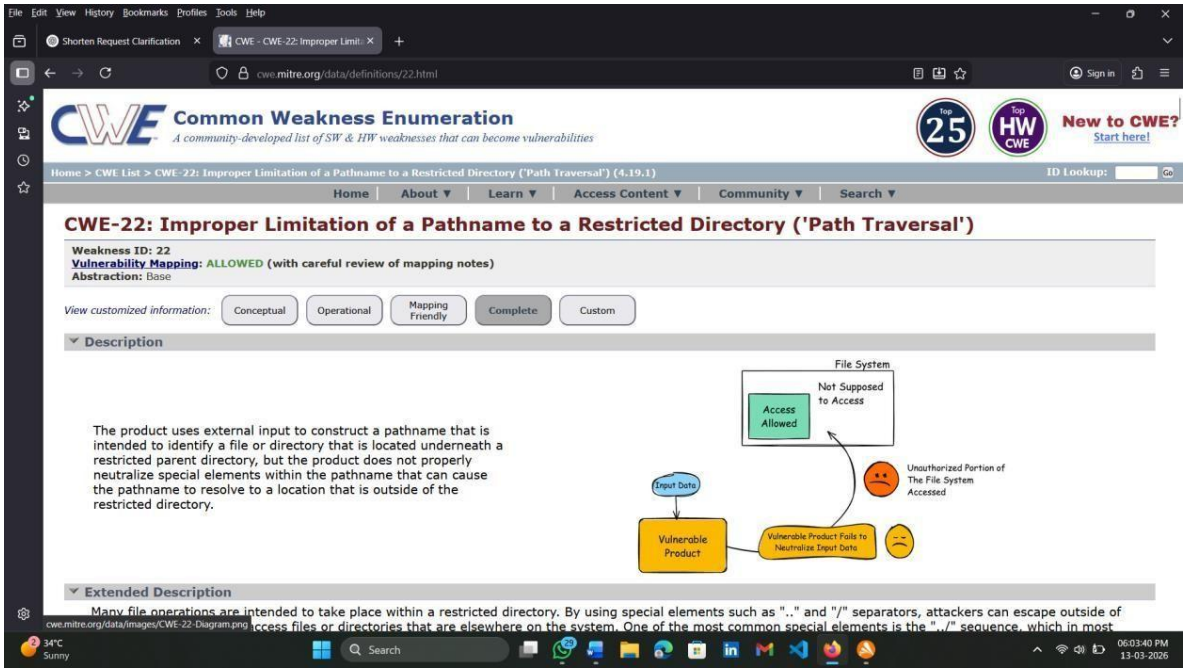
1) Vulnerability Name:
Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')

CWE/CVE:
CWE-22

OWASP/SANS Category:
A01:2025 Broken Access Control

Description:
Improper Access Control occurs when a system does not correctly restrict user permissions. This allows users to access data or perform actions that they are not authorized to perform due to missing or weak authorization checks.

Business Impact:
This vulnerability can lead to unauthorized access to sensitive information, data modification, or misuse of system resources. It may result in data breaches, financial loss, and damage to an organization's reputation.



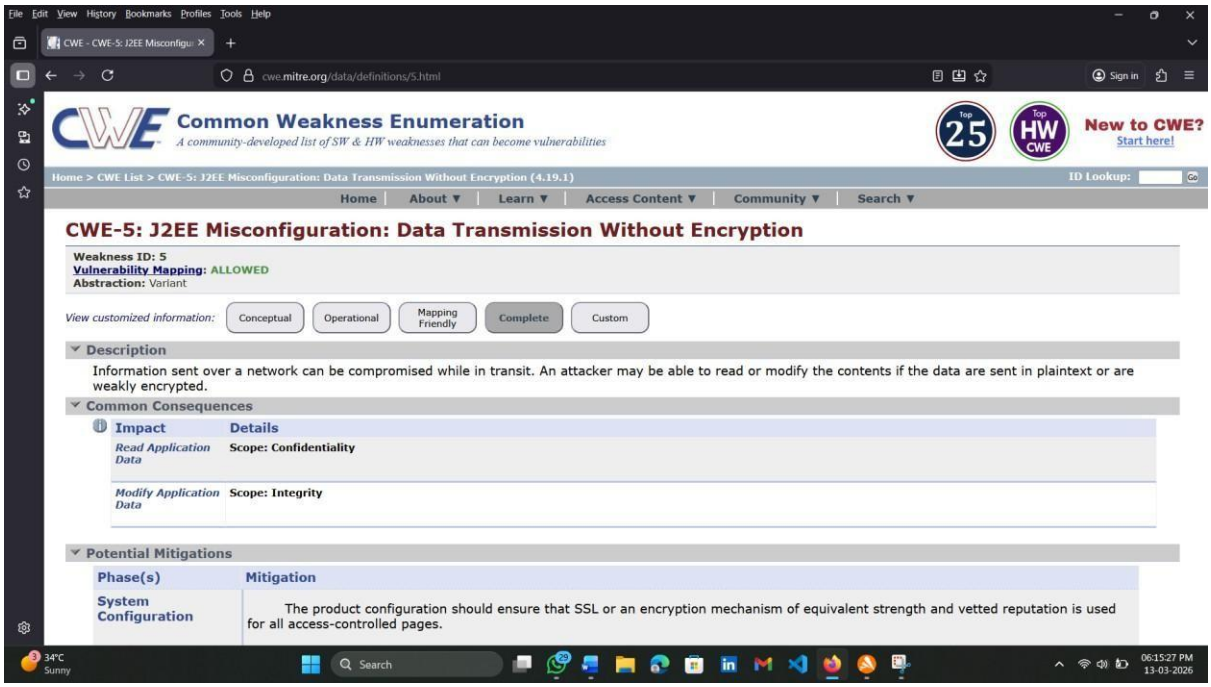
2) Vulnerability Name:
J2EE Misconfiguration: Data Transmission Without Encryption

CWE/CVE:
CWE-5

OWASP/SANS Category:
A02:2025 security Misconfiguration

Description:
Improper Authorization occurs when a system fails to correctly verify whether a user has permission to perform a specific action or access certain resources. As a result, users may be able to perform operations beyond their assigned privileges.

Business Impact:
This vulnerability can allow unauthorized users to access restricted data or perform sensitive operations. It may lead to data breaches, unauthorized system changes, and potential financial and reputational damage to the organization.



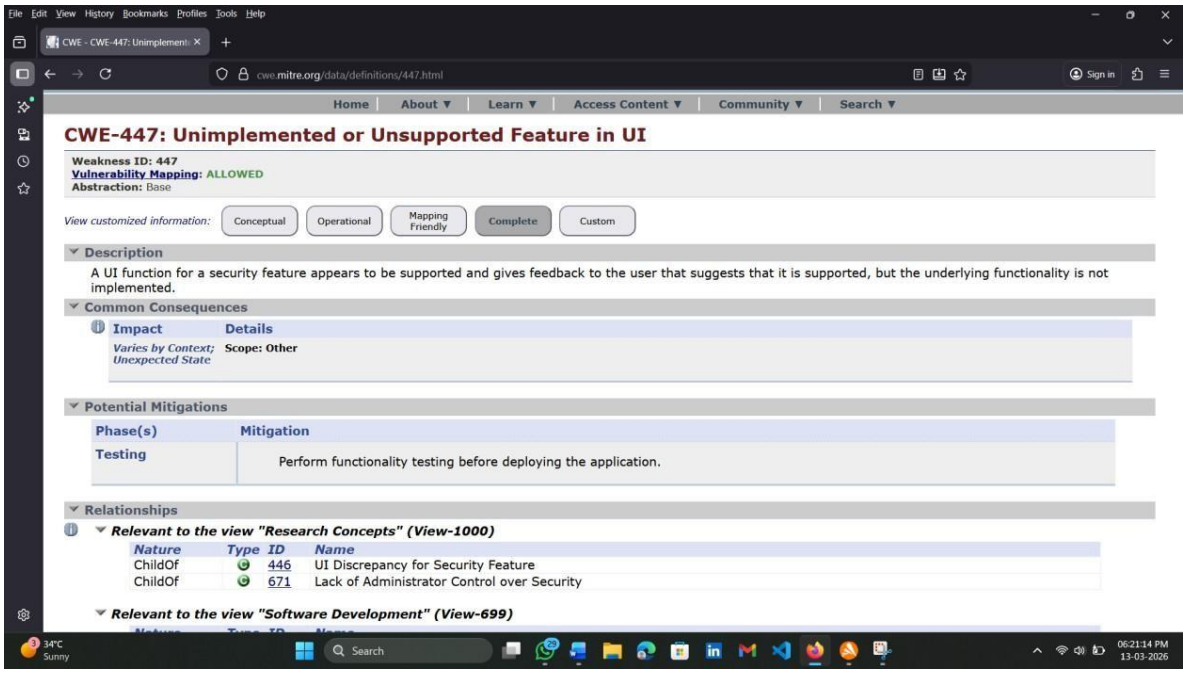
3) **Vulnerability Name:**
Unimplemented or Unsupported Feature in UI

CWE/CVE:
CWE-447

OWASP/SANS Category:
A03:2025 Software Supply Chain Failures

Description:
This vulnerability occurs when a system unintentionally exposes sensitive personal information such as names, addresses, phone numbers, or financial details to unauthorized users. It usually happens due to weak security controls or improper data protection mechanisms.

Business Impact:
Exposure of personal information can lead to privacy violations, identity theft, and legal consequences for organizations. It can also damage customer trust and harm the organization's reputation.



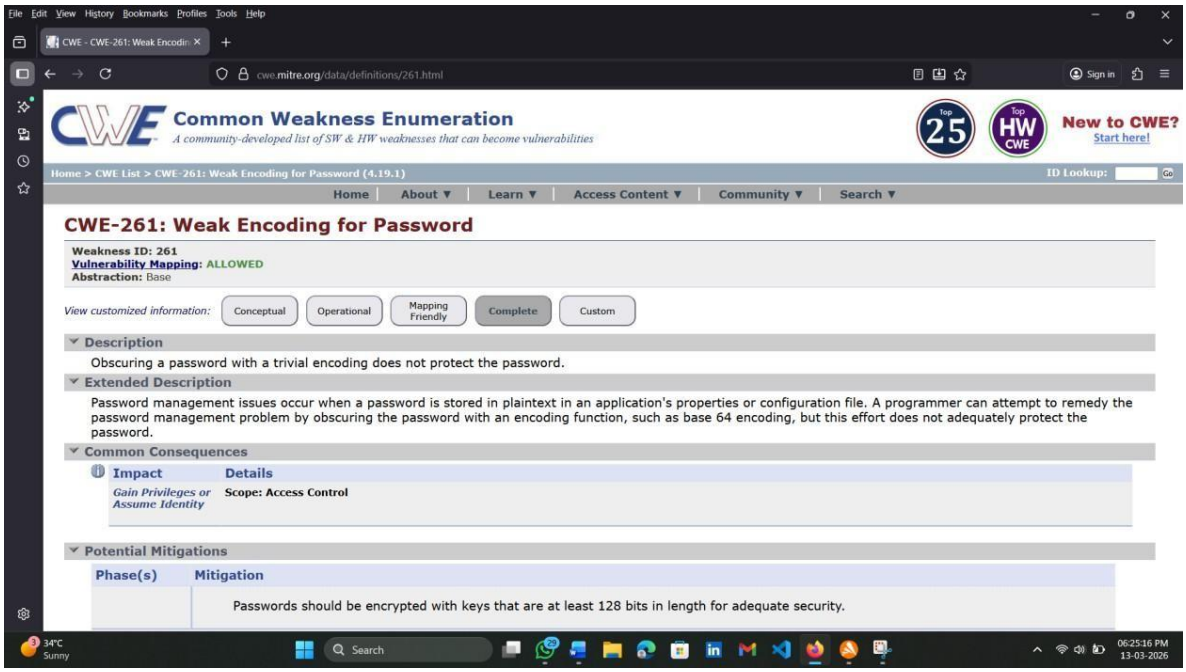
4) Vulnerability Name:
weak Encoding For Password

CWE/CVE:
CWE-261

OWASP/SANS Category:
A04:2025 -Cryptographic Failures

Description:
This vulnerability occurs when a system improperly controls how external programs or processes are loaded or executed. Attackers may exploit this weakness to run malicious code within the application.

Business Impact:
Exploitation of this vulnerability can allow attackers to execute unauthorized programs, potentially leading to system compromise, data breaches, or disruption of business operations.



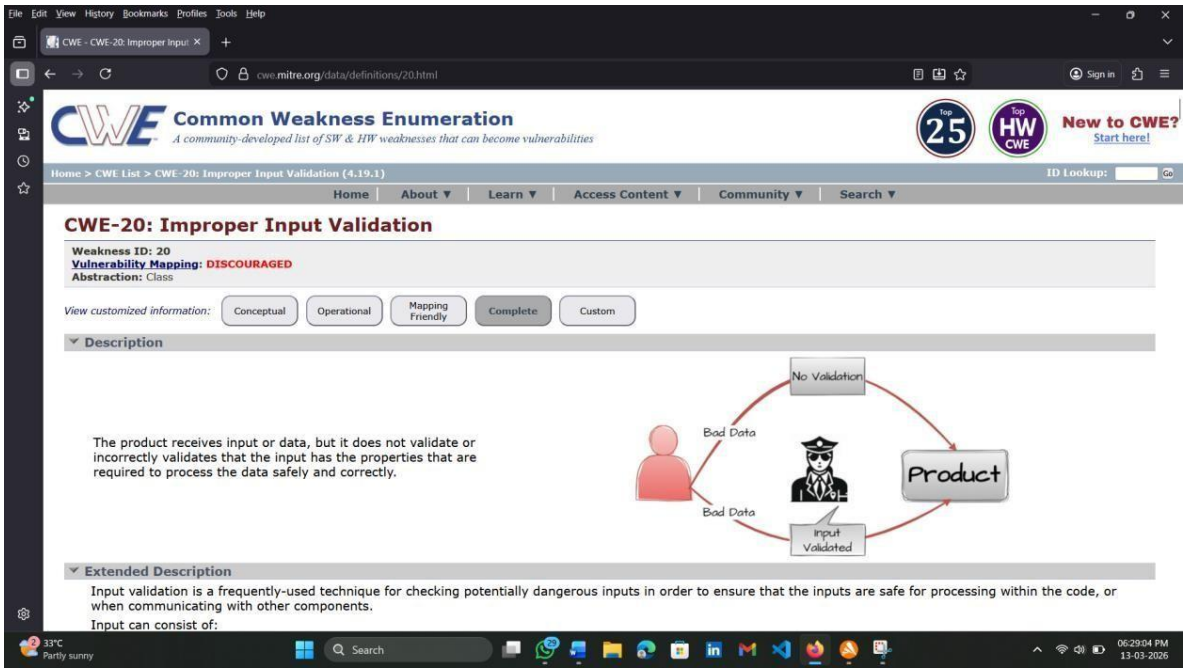
5) Vulnerability Name:
improper Input Validation

CWE/CVE:
CWE-20

OWASP/SANS Category:
A05:2025 - Injection

Description:
This vulnerability occurs when passwords are stored directly in configuration files without proper protection. If attackers gain access to these files, they can easily retrieve the credentials and misuse them.

Business Impact:
Exposed passwords may allow attackers to gain unauthorized access to systems, databases, or applications. This can result in data breaches, system compromise, and significant security risks for the organization.



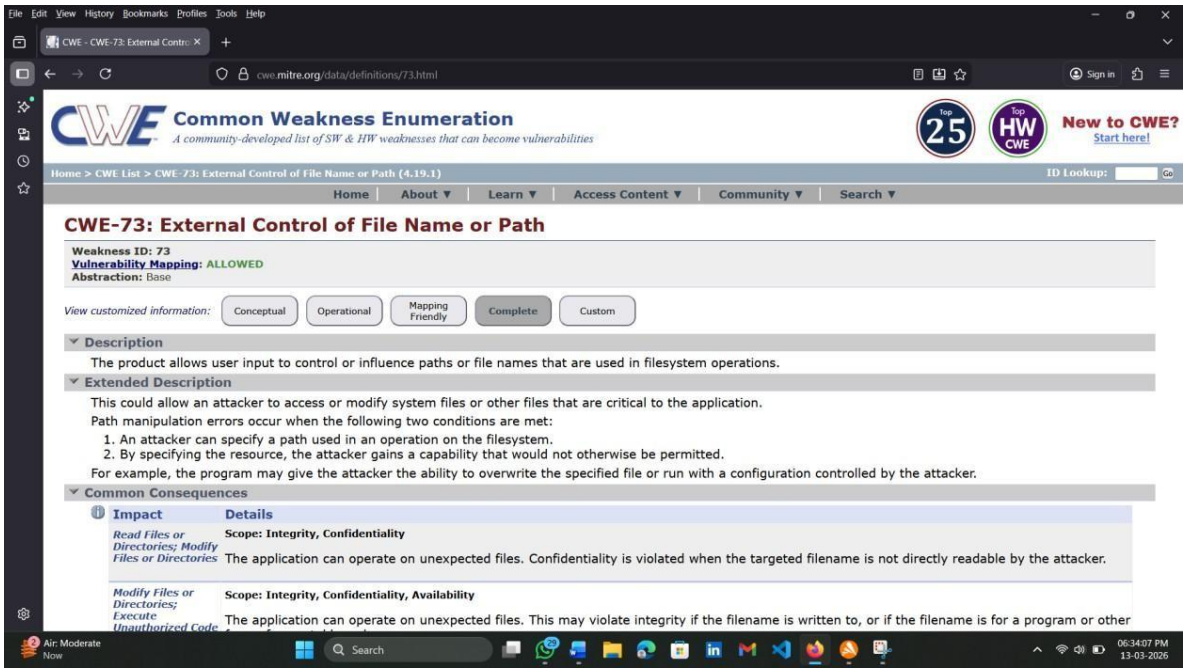
6) Vulnerability Name:
External Control of File Name or Path

CWE/CVE:
CWE-73

OWASP/SANS Category:
A06:2025 Insecure design

Description:
This vulnerability occurs when an application relies on third-party libraries or components that contain known security flaws. If these components are not updated or properly managed, attackers may exploit their vulnerabilities to compromise the system.

Business Impact:
Using vulnerable third-party components can expose the system to security attacks, data breaches, or unauthorized access. It may also lead to system instability, operational risks, and damage to the organization's reputation.



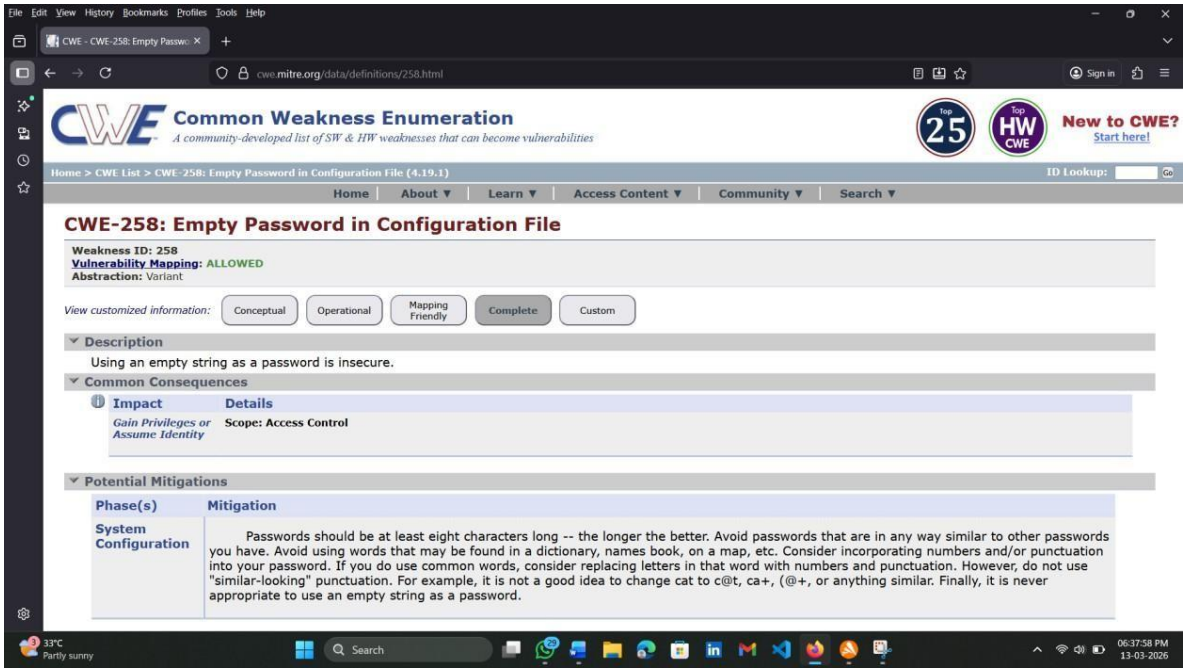
7) **Vulnerability Name:**
Empty Password in Configuration file

CWE/CVE:
CWE-258

OWASP/SANS Category:
A07:2025 –Authentication Failures

Description:
This vulnerability occurs when a system does not properly verify cryptographic signatures used to validate the authenticity and integrity of data or software. As a result, modified or malicious data may be accepted as valid.

Business Impact:
Attackers may exploit this weakness to bypass security checks, distribute malicious content, or tamper with sensitive data, leading to system compromise and security breaches.



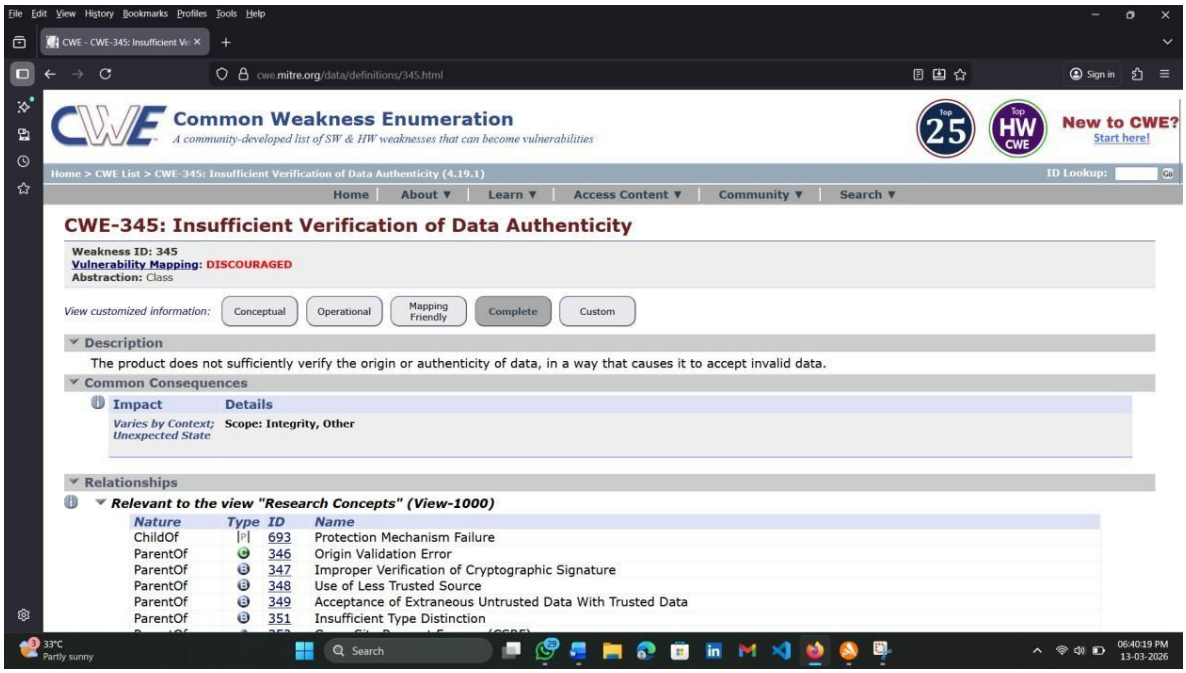
8) Vulnerability Name:
Insufficient Verification of Data Authenticity

CWE/CVE:
CWE-345

OWASP/SANS Category:
A08:2025 Software or Data Integrity Failures

Description:
This vulnerability occurs when a system does not properly validate digital certificates during secure communication. As a result, attackers may present fake or invalid certificates and intercept or manipulate the communication.

Business Impact:
Improper certificate validation can allow attackers to perform man-in-the-middle attacks, steal sensitive information, or compromise secure communications, leading to serious security risks for the organization



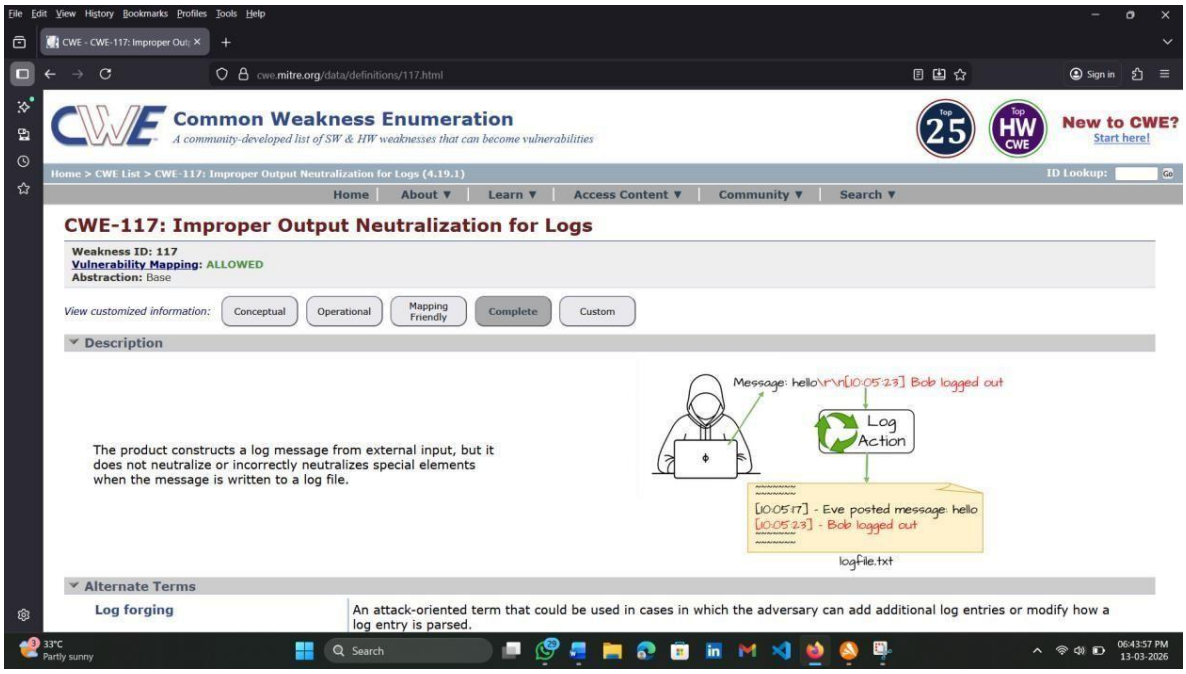
9) Vulnerability Name:
Improper Output Neutralization for Logs

CWE/CVE:
CWE-117

OWASP/SANS Category:
A09:2025 Security Logging and Alerting Failures

Description:
This vulnerability occurs when a system searches for executable files in untrusted directories before trusted ones. Attackers can place malicious files in these locations, causing the system to execute the attacker's code instead of the intended program.

Business Impact:
Exploitation of this vulnerability can allow attackers to execute malicious code, gain unauthorized system access, or compromise system integrity, leading to serious security and operational risks.



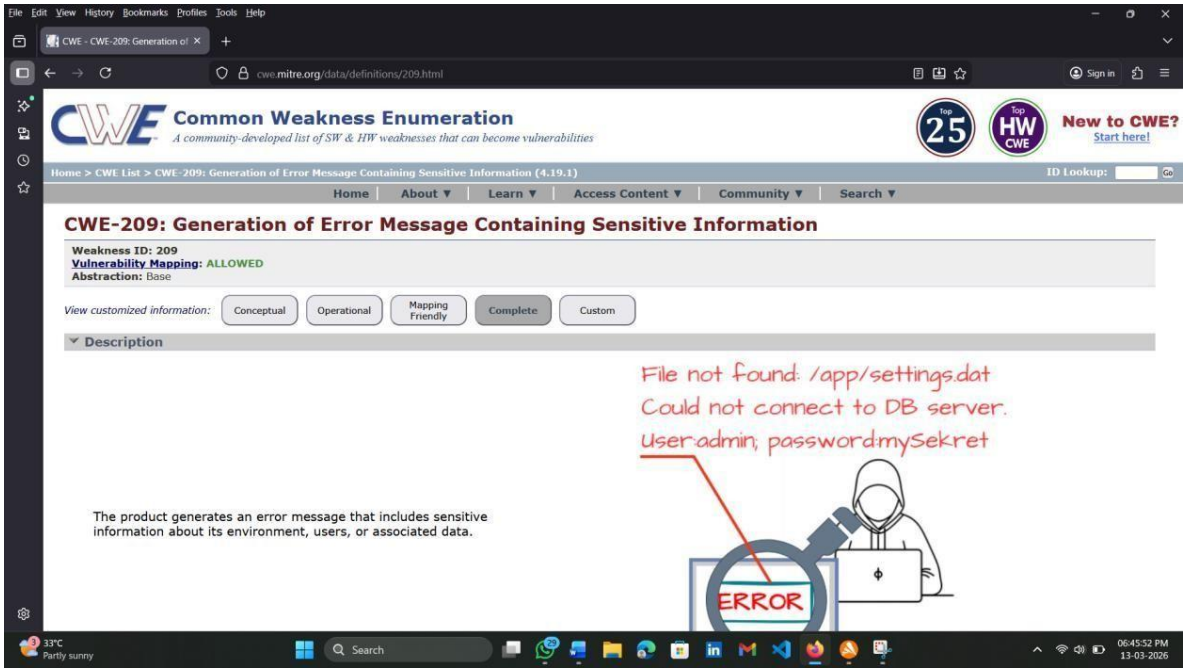
10) **Vulnerability Name:**
Generation of Error Message Containing Sensitive Information

CWE/CVE:
CWE-209

OWASP/SANS Category:
A10:2025 Mishandling of Exceptional Conditions

Description:
This vulnerability occurs when a system does not properly record important security events or user activities. As a result, suspicious actions or attacks may go unnoticed.

Business Impact:
Without proper logging, organizations may be unable to detect, investigate, or respond to security incidents effectively. This can lead to prolonged attacks, data breaches, and difficulty in identifying the source of security issues.



Stage 2

Overview :-

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests.

Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

In addition to vulnerability detection, Nessus also helps organizations improve their overall security posture by providing detailed insights into system weaknesses and configuration issues. The tool prioritizes vulnerabilities based on their severity levels, such as critical, high, medium, and low. This prioritization allows security teams to focus on the most serious threats first and take immediate corrective actions. By regularly performing vulnerability scans using Nessus, organizations can reduce the risk of cyberattacks and ensure that their systems remain secure and up to date.

Another important feature of Nessus is its ability to generate comprehensive and easy-to-understand reports. These reports provide a clear overview of all detected vulnerabilities, along with recommendations for remediation. System administrators and security professionals can use these reports to patch vulnerabilities, update software, and improve system configurations. As a result, Nessus plays a crucial role in maintaining a secure IT environment and supporting proactive cybersecurity management within organizations.

Here is a step-by-step explanation of how Nessus works:

1. Target Identification
First, the user defines the target systems that need to be scanned. These targets may include individual hosts, servers, network devices, or web applications within a network environment.

2. Connection to the Target Host
Nessus connects to the target host using various network protocols such as TCP, UDP, and ICMP in order to communicate with the system and begin the scanning process.

3. Host Discovery
The scanner performs a discovery process to determine whether the target host is active. During this phase, Nessus identifies live hosts within the network.

4. Port Scanning
Nessus scans the target host to detect open ports and running services. This helps identify which services are available and potentially vulnerable.

5. Operating System and Service Detection
Nessus sends a series of probes to the target system to identify the operating system, applications, and services running on the host.

6. Vulnerability Testing Using Plugins
Nessus executes a large set of plugins designed to check for specific vulnerabilities, misconfigurations, outdated software, or missing security patches.

7. Vulnerability Analysis
The system analyzes the collected information and determines the severity level of each detected vulnerability based on risk factors and known security databases.

8. Report Generation
Finally, Nessus generates a detailed report that includes the severity of each vulnerability, possible risks, steps to reproduce the vulnerability, and recommendations for remediation.

Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to prioritise remediation efforts.

Here are some of the benefits of using Nessus:

- Comprehensive vulnerability coverage: Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices.
- Easy to use: Nessus has a user-friendly interface that makes it easy to configure and run scans.
- Comprehensive reporting: Nessus provides detailed reports that include the severity of each vulnerability,the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.
- Scalability: Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.
- Flexibility: Nessus can be configured to run scans on a schedule or manually.

Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable asset for any security professional.

Target website :- http://testfire.net/

Target ip address:- 65.61.137.117

List of vulnerability:-

s.no	Vulnerability name	Severity	plugins
1	TLS Version 1.0 Protocol Detection	MEDIUM	104743
2	TLS Version 1.1 Protocol Deprecated	MEDIUM	157288
3	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)	LOW	83875
4	ICMP Timestamp Request Remote Date Disclosure	INFO	10114
5	Additional DNS Hostnames	INFO	46180
6	Apache Tomcat Detection	INFO	39446
7	Common Platform Enumeration (CPE)	INFO	45590
8	Device Type	INFO	54615
9	HSTS Missing From HTTPS Server	INFO	84502
10	HTTP Server Type and Version	INFO	10107
11	Service Detection	INFO	22964

REPORT: -

1) **Vulnerability Name: - 104743 - TLS Version 1.0 Protocol Detection Severity: -** MEDIUM

Plugin: - 104743

Port: - 443

Description:

The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible.

As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI terminals (and the SSL/TLS termination points to which they connect) that can be verified as not being susceptible to any known exploits.

Solution: - Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

Business Impact:

Continued use of TLS 1.0's encryption, known for its inherent cryptographic flaws, exposes the organization to heightened security risks, increasing the likelihood of data breaches and cyberattacks. This vulnerability jeopardizes compliance with industry standards, specifically PCI DSS v3.2, which mandates the complete cessation of TLS 1.0 use. Non- compliance risks regulatory penalties and erodes customer trust. Moreover, endpoints that lack support for TLS 1.2 and higher will experience impaired functionality with major web browsers and vendors, potentially leading to lost business opportunities and damage to the organization's reputation. Addressing this vulnerability is imperative to mitigate these multifaceted risks and maintain a secure and trustworthy online presence.

2) **Vulnerability Name: - 157288 - TLS Version 1.1 Protocol Deprecated Severity: -** MEDIUM

Plugin: - 157288

Port: - 443

Description:

The remote service accepts connections encrypted using TLS 1.1. TLS 1.1 lacks support for current and recommended cipher suites. Ciphers that support encryption before MAC computation, and authenticated encryption modes such as GCM cannot be used with TLS 1.1 as of March 31,2020, Endpoints that are not enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

Solution: - Enable support for TLS 1.2 and/or 1.3, and disable support for TLS 1.1.

Business Impact:

The continued use of TLS 1.1 with its lack of support for modern cipher suites and advanced encryption methods jeopardizes the organization's security posture, increasing vulnerability to cyber threats and potential data breaches. Additionally, endpoints not upgraded to support TLS 1.2 and higher will encounter compatibility issues with major web browsers and vendors, impacting user experience and potentially leading to missed business opportunities. Swift remediation of this vulnerability is essential to mitigate security risks and ensure seamless interactions with web browsers and vendors, preserving the organization's reputation and operational efficiency.

3) **Vulnerability Name: - 83875 - SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)**
Severity: - LOW

Plugin: - 83875

Port: - 443

Description:

The remote host allows SSL/TLS connections with one or more Diffie-Hellman moduli less than or equal to 1024 bits. Through cryptanalysis, a third party may be able to find the shared secret in a short amount of time (depending on modulus size and attacker resources). This may allow an attacker to recover the plaintext or potentially violate the integrity of connections.

Solution: - Reconfigure the service to use a unique Diffie-Hellman moduli of 2048 bits or greater.

Business Impact:

Allowing SSL/TLS connections with weak Diffie-Hellman moduli raises security concerns. An attacker with sufficient resources and computing power could compromise the shared secret relatively quickly, potentially leading to the decryption of sensitive data or the violation of connection integrity. While the severity is low, the risk of data breaches and integrity compromise should not be underestimated, and it is essential to address this vulnerability to maintain data security and user trust.

4) Vulnerability Name: - 10114 - ICMP Timestamp Request Remote Date Disclosure
Severity: - INFO

Plugin: - 10114

Port: - 0

Description:

The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols.

Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time.

Solution: - Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

Business Impact:

This does not pose an immediate threat to business operations or data security. This vulnerability allows external parties to request the system's date and time information remotely. While it does not present a significant risk, it could potentially be used by attackers for reconnaissance purposes. Therefore, it is advisable to address this vulnerability as part of a broader security posture to reduce the risk of unauthorized data gathering and protect against potential future threats.

5) **Vulnerability Name: - 46180 - Additional DNS Hostnames Severity: -** INFO

Plugin: - 46180

Port: - 0

Description: -

Hostnames different from the current hostname have been collected by miscellaneous plugins. Nessus has generated a list of hostnames that point to the remote host. Note that these are only the alternate hostnames for hosts discovered on a web server.

Different web servers may be hosted on name-based virtual hosts.

Solution: - If you want to test them, re-scan using the special vhost syntax, such as : www.example.com [192.0.32.10]

Business Impact:

This does not pose an immediate threat to business operations or data security. It indicates the discovery of hostnames that are associated with the remote host, particularly in cases of web servers utilizing name-based virtual hosts. While not a security risk on its own, it could be useful for understanding the server's configuration and infrastructure.

Organizations should consider this information as part of their network documentation but do not need to take immediate action to mitigate it as a security threat.

6) **Vulnerability Name: - 39446 - Apache Tomcat Detection Severity: -** INFO

Plugin: - 39446

Port: - 80

Description:

Nessus was able to detect a remote Apache Tomcat web server.

Solution: - n/a

Business Impact:

Is an informational finding that identifies the presence of a remote Apache Tomcat web server. While this information itself does not indicate a security threat or impact on business operations, it can be useful for network administrators and security professionals to be aware of the technologies in use on their network. Understanding the presence of an Apache Tomcat server can be valuable for maintaining and securing web applications, but it does not require immediate action to mitigate a security risk.

7) **Vulnerability Name: - 45590 - Common Platform Enumeration (CPE) Severity: -** INFO

Plugin: - 45590

Port: - 0

Description:

By using information obtained from a Nessus scan, this plugin reports CPE (Common Platform Enumeration) matches for various hardware and software products found on a host.

Note that if an official CPE is not available for the product, this plugin computes the best possible CPE based on the information available from the scan.

Business Impact:

This provides insights into hardware and software products identified on a host through a Nessus scan. It reports CPE matches, which are standardized identifiers for these products. This information is valuable for asset management and inventory purposes. While it doesn't signify a security threat, it aids administrators in understanding the components within their network, contributing to effective resource management and facilitating future system maintenance.

8) **Vulnerability Name: - Device Type Severity:** - INFO

Plugin: - 54615

Port: - 0

Description:

Based on the remote operating system, it is possible to determine what the remote system type is (eg: a printer, router, general-purpose computer, etc).

Solution: -

Business Impact:

It allows for the identification of the remote system type, such as a printer, router, or general-purpose computer, based on the remote operating system. While this doesn't pose a direct security threat, it offers valuable insights for network administrators to better understand and classify the devices in their network. This information aids in network management, optimization, and ensures that the right security measures are in place for each device type.

9) Vulnerability Name: - 84502 - HSTS Missing From HTTPS Server Severity: - INFO

Plugin: - 84502

Port: - 443

Description:

The remote HTTPS server is not enforcing HTTP Strict Transport Security (HSTS). HSTS is an optional response header that can be configured on the server to instruct the browser to only communicate via HTTPS. The lack of HSTS allows downgrade attacks, SSL- stripping man-in-the-middle attacks, and weakens cookie- hijacking protections.

Solution: - Configure the remote web server to use HSTS**.**

Business Impact:

Indicates that the remote HTTPS server does not enforce HTTP Strict Transport Security (HSTS). HSTS is a crucial security feature that, when configured on the server, instructs web browsers to communicate exclusively via HTTPS, enhancing security. The absence of HSTS potentially exposes the server to downgrade attacks, SSL-stripping

10) Vulnerability Name: -22964-Service Detection:-INFO

Plugin: - 22964

Port: - 0

Description:

The remote host is running one or more services that were identified by the scanning engine during the security assessment. This plugin reports the detected services and their associated ports.Service detection help identify applications and protocols running on the target system, which can assist in further vulnerability analysis.Service detection works by analyzing responses from open ports and matching them with known service signatures. This process allows the scanner to determine which services are active and accessible on the system.

Solution:

No remediation is required as this is an informational finding. However, administrators should review the detected services and ensure that only necessary services are exposed to the network Unnecessary or unused services should be disabled to reduce the potential attack surface.

Business Impact:

This informational finding indicates which services are currently running on the target host. While it does not represent a vulnerability by itself, exposed services may increase the attack surface if they are outdated, misconfigured, or unnecessary. Regular review and management of running services help maintain a secure network environment.

11) Vulnerability Name: - 10107 - HTTP Server Type and Version Severity: - INFO

Plugin: - 10107

Port: - 443

Description:

This plugin attempts to determine the type and the version of the remote web server.

Solution: - N/A

Business Impact:

This relates to the identification of the remote web server's type and version. While this issue doesn't pose an immediate security threat, it can provide valuable information to potential attackers about the server's software stack. Knowledge of the server type and version may aid attackers in exploiting known vulnerabilities specific to that software, making it important to restrict such information from being easily accessible to enhance the server's overall security posture.

Stage 3

Title: Enhancing system security through identity based on context aware access control

Zero Trust Network Access (ZTNA)

Zero Trust Network Access (ZTNA) is an IT security framework that provides secure remote access to an organization's internal applications and data based on clearly defined access control policies. Unlike traditional Virtual Private Networks (VPNs), which grant users broad access to the entire network, ZTNA operates on a "never trust, always verify" principle. It grants users access only to the specific applications they need, and only after their identity and device have been verified.

ZTNA is a critical component of modern security architecture. It helps organizations move away from the concept of a trusted internal network and an untrusted external network (the "castle- and-moat" model). By hiding the internal network from the internet and establishing one-to-one, encrypted connections between users and applications, ZTNA drastically reduces the attack surface and stops common threats like lateral movement by attackers.

• The ZTNA Access Cycle

The ZTNA cycle is a continuous process of verifying identity, establishing secure connections, and enforcing policy for every access request. It typically consists of the following steps:

1. User Request: A user, from any location (office, home, coffee shop), requests access to a specific internal application (e.g., an HR portal, a finance server, or an internal code
2. Identity and Device Verification: Before any connection is established, the ZTNA solution verifies who the user is (via multi-factor authentication, or MFA) and checks the security posture of their device. This includes ensuring the device has up-to-date antivirus, a healthy firewall, and is not compromised.
3. Policy Enforcement: The ZTNA solution checks the access policy. Does this specific user, with this specific device, have permission to access the requested application at this specific time?
4. Establish Secure Connection: If the policy allows access, the ZTNA solution creates a highly secure, encrypted micro-tunnel between the user's device and the target application. Crucially, the user never gains access to the underlying network, only to the application itself.

5. Continuous Monitoring: The ZTNA solution continues to monitor the connection for anomalies. If the user's behavior becomes suspicious or their device posture changes, the connection can be terminated in real-time.
6. Logging and Analytics: All access attempts, successful and failed, are logged and analyzed. This data is used for auditing, threat hunting, and refining access policies.

• Zscaler (Zscaler Internet Access / Zscaler Private Access)

Zscaler is a cloud-native security platform that delivers its services entirely from the cloud, eliminating the need for on-premises hardware like VPN concentrators. For ZTNA, Zscaler offers Zscaler Private Access (ZPA) . ZPA is a service that provides seamless, identity-based access to private applications without ever placing users on the network.

Zscaler ZPA operates on a simple principle: the application is "inside" the Zscaler cloud, and the user connects to it there. It collects data from a variety of sources, including:

1. Identity Providers (IdP): Such as Azure AD, Okra, or Ping Identity, to verify user identities.
2. Device Posture Partners: Such as CrowdStrike, Tanium, or Microsoft Defender for Endpoint, to check the health of the endpoint.
3. Business Applications: The internal web apps, file servers, and legacy applications hosted in data centers or public clouds (e.g., AWS, Azure).
4. Zscaler App Connectors: Lightweight software components deployed in the data center or cloud that initiate outbound connections to the Zscaler cloud, making internal servers invisible to the internet.

Zscaler then enforces policies based on this data, including:

1. Identity-Based Access: Policies are built around user and group identities, not IP addresses.
2. Application Segmentation: Users are granted access to specific applications, not entire subnets.
3. Least Privilege Access: Ensures users have the minimum level of access required to perform their jobs.

The Zscaler ZTNA Cycle

The Zscaler ZTNA cycle is the practical application of the ZTNA principles using the Zscaler cloud. The cycle typically consists of the following steps:

1. User Login and Authentication: A user attempts to access an internal application. They are redirected to their organization's Identity Provider (IdP) for authentication and MFA.
2. Device Posture Check (Integration): Zscaler checks with integrated endpoint protection tools to ensure the device is compliant with security policies.
3. Policy Lookup and Decision: The Zscaler cloud evaluates the request against the defined access policies. It verifies that the user, device, and context (time, location) are authorized for that specific application.
4. Establishing the Micro-tunnel: Once authorized, the Zscaler cloud instructs the user's Zscaler Client Connector and the appropriate Zscaler App Connector in the data center to establish an encrypted connection. The user is now connected to the application.
5. Traffic Inspection (Optional): For sanctioned applications, Zscaler can optionally inspect the traffic for data loss prevention (DLP) or to detect malware.
6. Logging and Analytics: All activity is logged in the Zscaler cloud portal for reporting, threat hunting, and compliance.

MISP (Malware Information Sharing Platform) Integration

While Zscaler is a primary access control tool, it can be enhanced by integrating with threat intelligence platforms like MISP.

1. Threat Intelligence Feed: MISP can aggregate and share threat intelligence about malicious domains, IPs, and URLs. This list of indicators of compromise (IOCs) can be fed into Zscaler's cloud.
2. Proactive Blocking: If a user, even one authorized by ZPA, attempts to access a known malicious site that has been flagged by the MISP feed, Zscaler Internet Access (ZIA) can block the request, preventing a potential infection.
3. Enhanced Visibility: Security teams can use MISP to cross-reference Zscaler logs. If a user's behavior is anomalous, the team can check MISP to see if the destination IP or domain is associated with a known threat actor or campaign.

The network includes:

- Core routers and switches
- Distribution routers and switches
- Wireless access points
- Firewalls and Intrusion Detection Systems (IDS)
- Internal Application Servers: Hosting the student information system, library resources, research data repositories, and administrative portals.
- Legacy VPN Concentrator: Currently providing broad network-level access for faculty and staff working remotely.

The need for ZTNA arises from the limitations of the current VPN model:

- Over-permissioned Access: Once on the VPN, a faculty member's compromised laptop could potentially scan and attack the entire internal network (lateral movement).
- Hidden Applications: Some research applications need to be accessed by external collaborators without granting them full network access.
- User Experience: The legacy VPN can be slow and cumbersome, often requiring users to route all their internet traffic through the university
- How you think you deploy ZTNA using Zscaler in your college

To deploy Zscaler ZTNA (ZPA) in your college, you would start by identifying the specific applications that need to be secured and the user groups that need access to them. This is a shift from securing the network to securing access to applications

The plan would need to include the following:

1. **Application Discovery:**Catalog all internal applications (e.g., ERP, library system, research servers, file shares) and identify which ones are currently exposed via the VPN.

2. **User Segmentation:** Define user groups (e.g., Students, Faculty - Research, Faculty - Admin, IT Staff, External Collaborators) and the specific applications each group needs.

3. **Deploying Zscaler App Connectors:** Install lightweight App Connector VMs in the university's data center. These connectors will establish outbound connections to the Zscaler cloud, making the application servers invisible to the public internet.

4. **Integrating Identity Provider:** Connect Zscaler to the university's existing Identity Provider (e.g., Microsoft Azure AD) to leverage current usernames, passwords, and MFA policies.

5. **Configuring Access Policies:** Create granular policies in the Zscaler admin portal. For example: "The 'Faculty' group can access the 'ERP Application' from any device that has antivirus enabled, after MFA."

6. **Deploying Zscaler Client Connector:** Students, faculty, and staff will install the Zscaler Client Connector on their laptops and mobile devices. This small client intelligently routes traffic for private applications through ZPA and public traffic through ZIA.

Threat Intelligence

In the context of Zscaler and ZTNA, threat intelligence is used to understand who is trying to access what, and from where. It helps move beyond simple identity checks to a more contextual understanding of risk.
Sources include:

1. Zscaler Cloud Logs: Internal logs provide real-time data on who is accessing which applications, from which locations, and on what devices.
2. External Threat Feeds (MISP): Information about new malware campaigns, phishing kits, or command-and-control servers being used by attackers.
3. Identity Provider Logs: Anomalies in login attempts, such as a user logging in from two geographically impossible locations in a short time, can signal a compromised account.

This intelligence is used for:

1. Adaptive Access Control: If threat intelligence suggests a user's location is high-risk, Zscaler can step-up authentication requirements or block access entirely.
2. Hunting for Compromised Accounts: Analysts can use Zscaler logs to see if a user is suddenly accessing applications they never have before, which could be a sign of credential theft.
3. Blocking Malicious Communication: Threat intelligence feeds can be used by Zscaler Internet Access (ZIA) to block outbound connections to known malicious sites, even if they originate from a user inside the university.

Incident Response (Adapted for ZTNA)

Incident response in a ZTNA model is faster and more targeted because the environment is inherently more controlled.

1. Detection: The SOC team detects an anomaly. For example, a faculty account is downloading an unusually high volume of data from a research server at 3 AM. Zscaler logs provide the exact details: the user, the device, the application, and the amount of data transferred.
2. Containment: The SOC team can instantly isolate the user. In the Zscaler portal, they can simply deactivate that user's access or block their specific device. Because there is no network- level access, this action immediately severs all connections to every application, preventing lateral movement.
3. Eradication: The compromised device is taken offline for malware scanning and cleaning by the IT helpdesk.
4. Recovery: Once the device is clean and the user's password is reset, the Zscaler policy is re- enabled, granting the user access again.
5. Post-incident review: The security team analyzes the logs to understand how the account was compromised (e.g., a phishing email) and updates Zscaler policies, perhaps by adding a block for similar malicious domains or tightening access rules for that specific research application.

Benefits of this incident response approach:

1. Near-Instant Containment: Actions take seconds in a cloud dashboard, not minutes or hours configuring firewall rules.
2. No Lateral Movement: The attacker is contained to the single compromised application, protecting the rest of the university's network.
3. Granular Forensics: Zscaler provides a detailed audit trail of every connection, making investigations faster and more accurate.
4. Compliance: This model helps demonstrate compliance with data protection regulations by proving that access to sensitive student or research data is tightly controlled and audited.

Understanding about the tool (Zscaler ZPA)

Zscaler Private Access (ZPA) is a cloud-based security solution designed to provide secure remote access to internal applications without exposing them to the public internet. It is based on the Zero Trust Network Access (ZTNA) model, which follows the principle of "never trust, always verify." This means that users and devices must be continuously verified before they are allowed to access applications or network resources. Unlike traditional VPN solutions, ZPA connects users directly to specific applications instead of giving them full network access, thereby reducing the risk of unauthorized access and potential security threats.

One of the key advantages of ZPA is its inherent scalability. Since it operates as a cloud service, ZPA can easily scale to support thousands of users and applications without requiring additional hardware or complex infrastructure upgrades. Organizations can provide secure access to employees working from different locations, including remote workers and mobile users. This flexibility makes ZPA an effective solution for modern workplaces where employees frequently access company resources from various devices and networks.

ZPA also enhances security by hiding internal applications from the internet, making them invisible to potential attackers. By ensuring that applications are not directly exposed, the attack surface is significantly reduced. In addition, ZPA uses strong authentication methods and integrates with identity providers to verify user identity before granting access. This ensures that only authorized users with the correct credentials and device conditions can access sensitive applications.

Another important feature of ZPA is its ability to monitor and log user activity. The platform provides detailed visibility into user connections and application access, allowing administrators to track access patterns and detect suspicious behavior. This capability helps organizations maintain better control over their network resources and respond quickly to potential security incidents.

Overall, Zscaler ZPA plays a crucial role in implementing modern security strategies. By combining identity-based authentication, context-aware access control, and cloud-based infrastructure, it enables organizations to securely connect users to applications while protecting sensitive data and systems from cyber threats.

Conclusion

In conclusion, the project on Enhancing System Security through Identity-Based Context-Aware Access Control provided a comprehensive understanding of modern security mechanisms used to protect digital systems and organizational networks. In the current digital era, cyber threats and unauthorized access attempts are increasing rapidly, making it essential for organizations to implement stronger and more intelligent security solutions. Traditional access control systems that rely only on usernames and passwords are no longer sufficient to protect sensitive information and critical resources.

This project highlighted the importance of combining identity verification with contextual information, such as device type, location, login time, and network conditions, to make more secure and reliable access decisions. By analyzing these contextual factors along with user identity, systems can detect unusual activities and prevent potential security breaches before they occur. This approach significantly improves the overall security posture of organizations by ensuring that only legitimate and verified users can access protected systems and resources.

Furthermore, the study demonstrated how context-aware access control can enhance security while still maintaining a smooth and efficient user experience. Instead of applying the same level of verification to every login attempt, the system can dynamically adjust its security requirements based on the risk level of the access request. This intelligent and adaptive security mechanism helps organizations protect their digital assets, reduce vulnerabilities, and maintain trust in their information systems.

Stage 1 focused on understanding the basic concepts of system security, including authentication, authorization, and identity management. This stage introduced the importance of protecting sensitive information and explained how traditional access control methods work. It also provided the theoretical foundation necessary to understand advanced security mechanisms used in modern systems.

Stage 2 explored vulnerability assessment using Nessus, one of the most widely used security scanning tools. By analyzing Nessus reports, potential vulnerabilities within systems and networks were identified. This stage emphasized the importance of regular security assessments in detecting weaknesses, enabling organizations to take preventive measures and strengthen their security posture.

Stage 3 introduced the concept of Zero Trust Network Access (ZTNA) and its implementation through Zscaler technologies. This stage demonstrated how identity-based and context-aware access control can protect systems by verifying user identity, device status, and access conditions before granting permission. It highlighted the benefits of eliminating traditional perimeter-based security and adopting a more secure, adaptive approach to controlling access.

Considering the future scope, the integration of identity-based security with advanced technologies such as artificial intelligence and behavioral analytics can further enhance system protection. Context-aware systems will become more intelligent, enabling real-time threat detection and automated policy enforcement.

In essence, this project provided valuable insights into how modern security tools and frameworks can work together to enhance system protection. By combining vulnerability assessment with identity-based context-aware access control, organizations can build stronger and more resilient security infrastructures capable of defending against evolving cyber threats.

Future Scope

The rapid growth of digital technologies, cloud computing, and interconnected systems has significantly increased the need for advanced cybersecurity mechanisms. Traditional security approaches that rely only on passwords or fixed access rules are no longer sufficient to protect sensitive information and critical systems. In this context, identity-based context-aware access control has emerged as an effective security solution that evaluates both user identity and contextual factors before granting access. The future scope of this technology is vast, as it will continue to evolve with emerging technologies and changing cybersecurity requirements.

One of the most important future developments in this field is the integration of Artificial Intelligence (AI) and Machine Learning (ML) into access control systems. AI-powered systems will be capable of continuously monitoring user behavior, analyzing access patterns, and identifying unusual activities that may indicate security threats. For example, if a user normally logs in from a specific location or device and suddenly attempts access from an unknown location, the system can detect the anomaly and trigger additional security verification. Machine learning algorithms will also help improve the accuracy of threat detection by learning from previous security incidents and adapting to new attack patterns.

Another significant area of future development is the implementation of Zero Trust security models in organizations. Zero Trust architecture is based on the principle of “never trust, always verify,” meaning that every user, device, and application must be authenticated and authorized before accessing system resources. In the future, identity-based context-aware access control will play a major role in supporting Zero Trust environments by ensuring that access decisions are based not only on identity but also on contextual factors such as device health, network conditions, and user behavior. This will greatly reduce the risk of unauthorized access and insider threats.

The increasing adoption of cloud computing and distributed systems will also expand the need for context-aware access control. Many organizations are moving their data and applications to cloud platforms, where employees, partners, and customers access resources from various locations around the world. In such environments, traditional security mechanisms are not sufficient because the network perimeter is no longer clearly defined. Identity-based context-aware security solutions will provide stronger protection by verifying users and devices before granting access to cloud resources. These systems will ensure that only authorized users operating under secure conditions can access critical applications and data.

Another important aspect of future development is the growth of remote work and mobile computing. With the increasing use of laptops, smartphones, and tablets for accessing organizational systems, security risks have become more complex. Context-aware access control systems will help address these challenges by evaluating multiple factors such as device type, operating system security status, location, and time of access. If a device does not meet security requirements, the system may restrict access or request additional authentication steps. This dynamic approach will help organizations maintain strong security while supporting flexible work environments.

The future of identity-based security will also include the wider adoption of advanced authentication technologies such as biometric authentication, multi-factor authentication (MFA), and behavioral authentication. Biometric methods such as fingerprint recognition, facial recognition, and voice recognition will provide stronger identity verification compared to traditional passwords. Multi-factor authentication will combine different verification methods, such as passwords, security tokens, and biometric data, to ensure that only legitimate users gain access to systems. Behavioral authentication will analyze user behavior patterns, such as typing speed, mouse movements, and login habits, to verify identity continuously.

Furthermore, the development of Internet of Things (IoT) devices will create new challenges and opportunities for context-aware access control systems. As more smart devices become connected to networks, ensuring secure communication between these devices will become increasingly important. Identity-based context-aware systems will help manage access permissions for IoT devices and ensure that only trusted devices can interact with critical systems. This will help prevent cyberattacks that target vulnerable IoT devices.

Another promising future direction is the automation of security policies and risk assessment processes. Modern organizations manage large networks with thousands of users and devices, making manual security management difficult. Context-aware access control systems will use automation to enforce security policies and respond to potential threats in real time. For instance, if suspicious activity is detected, the system can automatically block access, request additional authentication, or notify security administrators. Automated security responses will help organizations react quickly to cyber threats and reduce the risk of data breaches.

In addition, data analytics and predictive security technologies will enhance the capabilities of context-aware access control systems. Advanced analytics tools will analyze large volumes of security data to identify trends and potential vulnerabilities. Predictive security models will anticipate possible attacks before they occur, allowing organizations to take preventive measures. By combining identity verification, contextual analysis, and predictive analytics, future security systems will become more proactive and intelligent.

Another area where context-aware access control will play a crucial role is regulatory compliance and data protection. Many industries such as healthcare, finance, and government are required to follow strict data protection regulations. Identity-based context-aware access control systems will help organizations comply with these regulations by ensuring that sensitive information is accessible only to authorized users under secure conditions. Detailed access logs and monitoring capabilities will also support auditing and compliance reporting.

Finally, as cybersecurity threats continue to evolve, organizations will need scalable and flexible security frameworks that can adapt to changing technological environments. Identity-based context-aware access control systems will become more scalable, allowing organizations to manage security across multiple platforms, including on-premise networks, cloud environments, and mobile devices. These systems will provide centralized control and improved visibility into user activities, helping security teams maintain a strong security posture.

In conclusion, the future scope of identity-based context-aware access control is vast and highly significant for modern cybersecurity. The integration of AI, machine learning, Zero Trust architectures, advanced authentication methods, and automated security management will transform the way organizations protect their digital systems. As technology continues to advance, context-aware security solutions will become more intelligent, adaptive, and efficient in preventing cyber threats. By adopting these advanced security frameworks, organizations will be able to safeguard their critical assets, ensure secure access to information, and build a resilient digital infrastructure capable of facing future cybersecurity challenges.

Topic Explored :

Data Collection and Aggregation, Standardization and Normalisation, Enrichment and Analysis Sharing and Distribution, Integration with Security Tools, Customization and Flexibility,Automation and Orchestration, Community Involvement, Incident Response Support, Threat Intelligence Feeds, Soc and Siem

Tools explored: -

Nmap, Metasploit, Nessus, Kali Linux, OWASP ZAP, Burp Suite

THE END